

BỘ CÔNG THƯƠNG
TRƯỜNG ĐẠI HỌC CÔNG THƯƠNG TP.HỒ CHÍ MINH
KHOA CÔNG NGHỆ THÔNG TIN

-----❁-----



ĐỒ ÁN HỌC PHẦN:
PHÂN TÍCH LỖ HỒNG

ĐỀ TÀI: ĐÁNH GIÁ AN NINH HỆ THỐNG FIREWALL VÀ IDS
SỬ DỤNG SNORT VÀ IPTABLES KIỂM THỬ KHẢ NĂNG PHÁT
HIỆN VÀ NGĂN CHẶN XÂM NHẬP

Thành phố Hồ Chí Minh, tháng 04 năm 2026

BỘ CÔNG THƯƠNG
TRƯỜNG ĐẠI HỌC CÔNG THƯƠNG TP.HỒ CHÍ MINH
KHOA CÔNG NGHỆ THÔNG TIN



ĐỀ TÀI: ĐÁNH GIÁ AN NINH HỆ THỐNG FIREWALL VÀ IDS
SỬ DỤNG SNORT VÀ IPTABLES KIỂM THỬ KHẢ NĂNG PHÁT
HIỆN VÀ NGĂN CHẶN XÂM NHẬP

Giảng viên hướng dẫn Thành viên nhóm

ThS.Ngô Quốc Huy

Hoàng Tuyết Mai - 2033230181

Bùi Mỹ Linh - 2033230166

Nguyễn Hoàng Yến Hoa - 2033230088

Thành phố Hồ Chí Minh, tháng 04 năm 2026

LỜI CẢM ƠN

Trước tiên với tình cảm sâu sắc và chân thành nhất, cho phép nhóm em được bày tỏ lòng biết ơn đến nhà trường và tất cả các thầy cô đã tạo điều kiện hỗ trợ, giúp đỡ em trong suốt quá trình học tập và thực hiện Đồ án lần này. Trong suốt thời gian bắt đầu học tập tại trường đến nay, nhóm em đã nhận được rất nhiều sự quan tâm, giúp đỡ của quý Thầy và bạn bè.

Với lòng biết ơn sâu sắc nhất, nhóm em xin gửi đến quý Thầy Khoa Công Nghệ Thông Tin đã cùng với tri thức và tâm huyết của mình để truyền đạt vốn kiến thức quý báu cho chúng em trong suốt thời gian học tập tại trường. Nhờ có sự hướng dẫn, bảo ban của các Thầy nên nhóm chúng em mới có thể hoàn thành tốt đồ án của mình.

Một lần nữa, nhóm chúng em xin chân thành cảm ơn thầy Ngô Quốc Huy – người đã trực tiếp giúp đỡ, quan tâm, hướng dẫn nhóm em hoàn thành tốt Đồ án trong thời gian qua.

Bài báo cáo được thực hiện trong khoảng thời gian ngắn. Bước đầu đi vào thực tế của nhóm em còn hạn chế và còn nhiều bất ngờ nên không tránh khỏi những thiếu sót, chúng em rất mong nhận được những ý kiến đóng góp quý báu của quý Thầy để kiến thức của nhóm em trong lĩnh vực được hoàn thiện hơn đồng thời có điều kiện bổ sung, nâng cao ý thức của mình

MỤC LỤC

LỜI CẢM ƠN.....	3
PHÂN CÔNG CÔNG VIỆC	5
DANH MỤC BẢNG.....	5
MỤC LỤC HÌNH ẢNH.....	8
PHẦN MỞ ĐẦU.....	9
CHƯƠNG 1: TỔNG QUAN VỀ AN NINH MẠNG.....	11
1.1. Khái niệm an ninh hệ thống.....	11
1.2. Các mối đe dọa phổ biến	11
1.3. Vai trò của bảo mật trong hệ thống	12
CHƯƠNG 2: FIREWALL VÀ IPTABLES.....	14
2.1. Khái niệm Firewall	14
2.2. Nguyên lý hoạt động.....	14
2.3. Các loại Firewall.....	16
2.4. Giới thiệu Iptables	16
CHƯƠNG 3: IDS VÀ CÔNG CỤ SNORT.....	18
3.1. Khái niệm IDS	18
3.2. Phân loại IDS.....	18
3.3. Phương pháp phát hiện	18
3.4. Giới thiệu Snort	19
CHƯƠNG 4: CÁC DẠNG TẤN CÔNG THỰC NGHIỆM.....	21
4.1 Mô hình hệ thống.....	21
4.1.1 Sơ đồ thực hiện.....	21
4.1.2 Nguyên lý hoạt động của luồng dữ liệu	22
4.2 Cấu hình môi trường ảo hóa (VMware Workstation)	22
4.3 Cấu hình địa chỉ IP và Định tuyến.....	24
4.3.1 Thiết lập IP tĩnh.....	24
4.3.2 Cấu hình Forwarding và Routing.....	25
4.4 Kiểm tra và Giám sát hệ thống	26
4.4.1 Kiểm tra kết nối.....	26
4.4.2 Cấu hình luật cho Snort IDS	27
CHƯƠNG 5: SO SÁNH FIREWALL VS IDS.....	29
CHƯƠNG 6: DEMO	30
TÀI LIỆU THAM KHẢO	31

PHÂN CÔNG CÔNG VIỆC

STT	Thành viên	Nội dung công việc chính
1	Bùi Mỹ Linh	Chủ trì cấu hình Iptables, Snort; Trực tiếp thực hiện demo kỹ thuật và chịu trách nhiệm nghiệm thu, rà soát chất lượng nội dung báo cáo cuối cùng.
2	Nguyễn Hoàng Yên Hoa	Thiết lập hạ tầng mạng Lab trên VMware; Phối hợp thực hiện demo và đảm nhiệm vai trò máy tấn công để kiểm thử hệ thống.
3	Hoàng Tuyết Mai	Biên soạn toàn bộ nội dung Word; Tổng hợp hình ảnh minh chứng từ quá trình demo, sơ đồ mạng và tài liệu tham khảo theo đúng định dạng.

DANH MỤC BẢNG

Bảng 1: So sánh các hành động xử lý gói tin trong Iptables: ACCEPT, DROP và REJECT.	15
Bảng 2: Thông số kỹ thuật và vai trò của các thiết bị trong hệ thống	21
Bảng 3: Các tiêu chí đánh giá khác biệt giữa Iptables và Snort trong an toàn mạng.	29

DANH MỤC CÁC TỪ VIẾT TẮT

STT	Từ viết tắt	Tiếng Anh	Tiếng Việt
1	AI	Artificial Intelligence	Trí tuệ nhân tạo
2	CIA	Confidentiality - Integrity - Availability	Bộ ba: Bảo mật - Toàn vẹn - Sẵn sàng
3	DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ phân tán
4	DoS	Denial of Service	Tấn công từ chối dịch vụ
5	HUIT	Ho Chi Minh City University of Industry and Trade	Trường Đại học Công Thương TP.HCM
6	ICMP	Internet Control Message Protocol	Giao thức điều khiển truyền tin Internet
7	IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập

8	IEEE	Institute of Electrical and Electronics Engineers	Học viện Kỹ sư Điện và Điện tử
9	IP	Internet Protocol	Giao thức liên mạng
10	IT	Information Technology	Công nghệ thông tin
11	LAN	Local Area Network	Mạng nội bộ
12	NXB		Nhà xuất bản
13	OS	Operating System	Hệ điều hành
14	SID	Snort ID	Mã định danh luật của Snort
15	SQL	Structured Query Language	Ngôn ngữ truy vấn có cấu trúc
16	TCP	Transmission Control Protocol	Giao thức điều khiển truyền vận
17	TLTK		Tài liệu tham khảo
18	VM	Virtual Machine	Máy ảo

MỤC LỤC HÌNH ẢNH

Hình 1: Mô hình tam giác CIA – Ba nguyên tắc cốt lõi trong an toàn và bảo mật thông tin.	11
Hình 2: Sơ đồ tư duy hệ thống mạng trong Cisco Packet Tracer	21
Hình 3: Cấu hình card mạng cho máy ảo Kali Linux trong VMware Workstation, thiết lập kết nối ở chế độ NAT để giao tiếp với mạng bên ngoài.	23
Hình 4: Thiết lập card mạng thứ hai cho máy ảo Ubuntu Server, kết nối vào phân đoạn mạng nội bộ (LAN segment: Lab_AnToanMang) để làm vùng được bảo vệ.	24
Hình 5: Cấu hình card mạng cho máy ảo nạn nhân (Windows) kết nối trực tiếp vào cùng LAN segment với máy chủ Ubuntu để thiết lập mạng nội bộ.....	24
Hình 6: Giao diện chỉnh sửa file cấu hình Netplan trên Ubuntu Server, thiết lập địa chỉ IP tĩnh cho giao diện ens33 (mạng ngoài) và ens37 (mạng trong: 10.0.0.1/24).	25
Hình 7: Sử dụng lệnh netsh trong Command Prompt trên Windows để đặt địa chỉ IP tĩnh (10.0.0.10) và Default Gateway (10.0.0.1) cho máy nạn nhân.	25
Hình 8: Kích hoạt tính năng chuyển tiếp IP trên Linux bằng lệnh sysctl, cho phép máy chủ đóng vai trò như một Router chuyển tiếp gói tin.	26
Hình 9: Thực hiện lệnh thêm định tuyến tĩnh trên Kali Linux để chỉ định đường đi đến dải mạng nội bộ 10.0.0.0/24 thông qua Gateway 192.168.232.1.	26
Hình 10: Kiểm tra kết nối mạng bằng lệnh Ping từ máy chủ Ubuntu tới cả máy tấn công (192.168.232.50) và máy nạn nhân (10.0.0.10) để xác nhận thông suốt.	27
Hình 11: Cấu hình các luật tùy chỉnh trong file local.rules của Snort IDS để phát hiện các gói tin ICMP và hành vi quét cổng Nmap.	28

PHẦN MỞ ĐẦU

1. Lý do chọn đề tài

Trong bối cảnh an ninh mạng diễn biến phức tạp, các phương thức tấn công ngày càng tinh vi khiến tường lửa truyền thống không còn đủ khả năng bảo vệ hệ thống toàn diện. Firewall thông thường chỉ lọc gói tin dựa trên địa chỉ và cổng, trong khi các mối đe dọa hiện nay thường ẩn mình sâu trong nội dung gói tin. Do đó, việc kết hợp giữa khả năng ngăn chặn mạnh mẽ của Iptables và khả năng giám sát, phân tích chuyên sâu của hệ thống phát hiện xâm nhập Snort là một giải pháp thiết yếu. Đề tài hướng tới xây dựng một hệ thống phòng thủ đa lớp, tối ưu hóa khả năng bảo mật trên nền tảng mã nguồn mở nhằm tiết kiệm chi phí nhưng vẫn đảm bảo tính hiệu quả cao.

2. Mục đích nghiên cứu

Mục tiêu cốt lõi của đề tài là nghiên cứu và làm chủ kỹ thuật cấu hình hệ thống bảo mật trên môi trường Linux. Cụ thể, nghiên cứu tập trung vào việc thiết lập chính sách lọc gói tin với Iptables và xây dựng tập luật cho Snort để nhận diện hành vi bất thường. Qua đó, đề tài xây dựng mô hình thực nghiệm có khả năng phát hiện và phản ứng tự động trước các hành vi xâm nhập, đồng thời đánh giá hiệu quả thực tế của hệ thống thông qua các kịch bản tấn công giả lập.

3. Phương pháp nghiên cứu

Đề tài được thực hiện dựa trên sự kết hợp giữa lý thuyết và thực nghiệm:

- Nghiên cứu lý thuyết: Tìm hiểu kiến trúc Netfilter, giao thức TCP/IP và cơ chế nhận dạng chữ ký tấn công của IDS.
- Thực nghiệm kỹ thuật: Xây dựng phòng Lab ảo hóa (VMware), thực hiện cài đặt và cấu hình trực tiếp các công cụ bảo mật trên Ubuntu Server và Kali Linux.
- Phân tích và đánh giá: Sử dụng các công cụ kiểm thử (Nmap, Hping3) để giả lập tấn công, từ đó phân tích nhật ký hệ thống (Logs) để đo lường độ chính xác và khả năng cảnh báo của hệ thống.

4. Phạm vi nghiên cứu

Nghiên cứu tập trung vào việc triển khai và phối hợp giữa hai công cụ mã nguồn mở chính là Iptables và Snort trên các bản phân phối Linux phổ biến. Nội dung kiểm thử giới hạn trong các kỹ thuật tấn công điển hình như quét cổng (Port Scan), tấn công từ chối dịch vụ và dò tìm mật khẩu. Đề tài tập trung vào cơ chế phòng thủ dựa trên tập luật định sẵn, không đi sâu vào các giải pháp thương mại hoặc ứng dụng Trí tuệ nhân tạo trong bảo mật.

CHƯƠNG 1: TỔNG QUAN VỀ AN NINH MẠNG

1.1. Khái niệm an ninh hệ thống

An ninh hệ thống là việc thiết lập các rào cản kỹ thuật và quy trình quản trị nhằm bảo vệ tài nguyên thông tin (phần cứng, phần mềm, dữ liệu). Mục tiêu cốt lõi là đảm bảo ba yếu tố: Tính bảo mật (Confidentiality), Tính toàn vẹn (Integrity) và Tính sẵn sàng (Availability).



Hình 1: Mô hình tam giác CIA – Ba nguyên tắc cốt lõi trong an toàn và bảo mật thông tin.

1.2. Các mối đe dọa phổ biến

Trong môi trường mạng hiện nay, hệ thống luôn phải đối mặt với các nguy cơ:

- Tấn công mạng (Cyber Attacks): Các hành vi như DoS/DDoS nhằm làm tê liệt hệ thống, hoặc Malware để phá hoại dữ liệu.
- Truy cập trái phép (Unauthorized Access): Việc kẻ tấn công vượt qua các cơ chế xác thực để chiếm quyền điều khiển hoặc đánh cắp dữ liệu nhạy cảm.
- Nghe lén (Sniffing): Sử dụng các công cụ bắt gói tin (như Wireshark) để theo dõi lưu lượng mạng, từ đó thu thập thông tin chưa được mã hóa như mật khẩu, nội dung email.
- Tấn công kỹ thuật xã hội (Social Engineering): Kẻ tấn công sử dụng email, tin nhắn hoặc danh nghĩa nhân viên kỹ thuật/quản lý để giả mạo các tổ

chức, cá nhân uy tín, từ đó dụ dỗ người dùng click vào link độc hại hoặc cung cấp tài khoản, mật khẩu và quyền truy cập trái phép.

- Tấn công lớp ứng dụng (Application Layer Attacks): Kẻ tấn công thực hiện chèn mã SQL độc hại hoặc các đoạn mã kịch bản trái phép vào hệ thống để truy vấn cơ sở dữ liệu, đánh cắp cookie hoặc chiếm đoạt phiên làm việc của người dùng.
- Mối đe dọa từ bên trong (Insider Threats): Các mối đe dọa từ bên trong, bao gồm nhân sự hiện tại hoặc cựu nhân viên, có thể gây ra sự cố lộ lọt dữ liệu thông qua các hành vi trục lợi có chủ đích hoặc do sơ suất vì thiếu hụt kiến thức bảo mật.
- Tấn công trung gian (Man-in-the-Middle): Kẻ tấn công thực hiện phương thức Man-in-the-Middle bằng cách can thiệp vào luồng giao tiếp giữa hai thực thể nhằm đánh chặn, nghe lén hoặc sửa đổi dữ liệu trái phép mà không làm gián đoạn kết nối.

1.3. Vai trò của bảo mật trong hệ thống

- Bảo mật đóng vai trò bảo vệ tổ chức trước các thiệt hại về tài chính và uy tín. Một hệ thống bảo mật tốt giúp duy trì sự hoạt động liên tục, ngăn chặn các hành vi xâm nhập từ sớm và tạo nền tảng tin cậy cho người dùng.
- Chiến lược Phòng thủ chiều sâu (Defense in Depth): Xây dựng hệ thống bảo mật đa tầng bằng cách kết hợp đồng bộ các giải pháp kỹ thuật như tường lửa, hệ thống phát hiện/ngăn chặn xâm nhập, phần mềm diệt virus và mã hóa dữ liệu nhằm triệt tiêu các điểm yếu đơn lẻ.
- Nguyên tắc Đặc quyền tối thiểu (Least Privilege): Kiểm soát truy cập nghiêm ngặt bằng cách chỉ cấp phát quyền hạn vừa đủ để người dùng hoàn thành chức trách chuyên môn, từ đó giảm thiểu tối đa phạm vi ảnh hưởng khi xảy ra sự cố bảo mật.
- Quản lý bản vá (Patch Management): Duy trì quy trình cập nhật định kỳ cho hệ điều hành và các ứng dụng phần mềm nhằm kịp thời khắc phục

các lỗ hổng bảo mật, đặc biệt là các lỗ hổng chưa được công bố, giúp bảo vệ hệ thống trước các nguy cơ khai thác mới.

CHƯƠNG 2: FIREWALL VÀ IPTABLES

2.1. Khái niệm Firewall

- Định nghĩa: Firewall là một thành phần phần cứng hoặc phần mềm nằm giữa hai vùng mạng (thường là mạng nội bộ và Internet), thực hiện vai trò lọc lưu lượng dựa trên các quy tắc bảo mật được thiết lập sẵn.

- Vai trò:

+ Kiểm soát traffic: Giám sát mọi luồng dữ liệu đi vào (Inbound) và đi ra (Outbound).

+ Ngăn chặn truy cập trái phép: Ngắt kết nối từ các IP đáng ngờ hoặc các dịch vụ không được phép mở.

2.2. Nguyên lý hoạt động

- Firewall phân tích các gói tin và ra quyết định dựa trên các thông tin trong Header của gói tin:

- Dựa trên:

+ Địa chỉ IP (nguồn/đích), Cổng - Port (ví dụ: 80 cho HTTP, 22 cho SSH), và Giao thức - Protocol (TCP, UDP, ICMP).

+ Cơ chế đối chiếu quy tắc (Rule Matching): Firewall kiểm tra các quy tắc theo thứ tự từ trên xuống, thực thi hành động ngay khi gói tin khớp và bỏ qua phần còn lại; nếu không khớp với bất kỳ quy tắc nào, hệ thống sẽ tự động loại bỏ gói tin theo nguyên tắc từ chối ngầm định (Implicit Deny) để đảm bảo an toàn.

+ Firewall quản lý lưu lượng qua các trạng thái: New để khởi tạo kết nối, Established để duy trì và tối ưu hiệu năng cho các phiên đã thiết lập, và Related để xử lý các kết nối phụ phát sinh liên quan, giúp hệ thống vận hành chính xác và bảo mật.

+ Phân tích sâu nội dung (Deep Packet Inspection): Khác với lọc gói tin thông thường, cơ chế DPI cho phép Firewall kiểm tra sâu vào phần dữ liệu để phát hiện mã độc ẩn nấp và nhận diện ứng dụng, giúp phân biệt chính xác các loại lưu lượng như Facebook hay Gmail ngay cả khi chúng cùng chạy trên cổng HTTPS.

- Cách xử lý packet:

- + ACCEPT: Cho phép gói tin đi qua.
- + DROP: Loại bỏ gói tin mà không gửi lại bất kỳ phản hồi nào cho nguồn gửi (kẻ tấn công sẽ thấy trạng thái "Timed out").
- + REJECT: Từ chối gói tin và gửi lại một thông báo lỗi cho nguồn gửi (thường là ICMP Destination Unreachable).

Bảng 1: So sánh các hành động xử lý gói tin trong Iptables: ACCEPT, DROP và REJECT.

Tiêu chí	ACCEPT	DROP	REJECT
Bản chất	Cho phép đi qua.	Chặn và giữ im lặng.	Chặn và phản hồi.
Phản hồi từ Firewall	Chuyển gói tin đến đích tiếp theo.	Không gửi bất kỳ tín hiệu nào.	Gửi gói tin ICMP (Destination Unreachable).
Trải nghiệm người dùng	Truy cập thành công, mượt mà.	Trình duyệt xoay vòng và báo "Timed out".	Báo lỗi "Connection Refused" ngay lập tức.
Góc độ bảo mật	Mở ra các lỗ hổng nếu cấu hình sai.	Tốt nhất (giúp ẩn hệ thống khỏi các công cụ quét cổng).	Thấp hơn (tiết lộ rằng tại IP đó có một Firewall đang chặn).
Tải tài nguyên (CPU/RAM)	Thấp (chỉ tốn công đối chiếu rule).	Thấp nhất (vứt bỏ gói tin ngay lập tức).	Cao hơn một chút (do phải tạo thêm gói tin phản hồi).

Trường hợp sử dụng	Cho các dịch vụ tin tưởng (HTTP, SSH, Mail).	Chặn các IP lạ, các cuộc tấn công từ Internet.	Chặn các dịch vụ trong mạng nội bộ để người dùng biết mà dừng lại.
---------------------------	--	--	--

2.3. Các loại Firewall

- Packet Filtering Firewall (Lọc gói tin): Hoạt động ở tầng Network, kiểm tra từng gói tin độc lập dựa trên IP/Port. Nhanh nhưng không hiểu được ngữ cảnh kết nối.
- Stateful Firewall (Lọc trạng thái): Nâng cao hơn, nó ghi nhớ trạng thái của các kết nối đang diễn ra (State table). Nếu một gói tin là một phần của kết nối đã được thiết lập, nó sẽ được cho qua nhanh hơn.
- Application Firewall (Tường lửa ứng dụng): Hoạt động ở tầng Application, có khả năng phân tích nội dung bên trong gói tin (như câu lệnh SQL, HTTP request) để chặn các cuộc tấn công tinh vi.
- Next-Generation Firewall (NGFW): Tường lửa thế hệ mới, hợp nhất lọc gói tin với hệ thống ngăn chặn xâm nhập (IPS) và kiểm tra sâu gói tin (DPI).
- Circuit-Level Gateway (Cổng cấp mạch): Hoạt động ở tầng Session, chỉ kiểm tra quá trình bắt tay TCP (Handshake) để xác nhận kết nối mà không soi chi tiết dữ liệu.
- Cloud Firewall / Firewall as a Service (FWaaS): Tường lửa dưới dạng dịch vụ trên đám mây, cho phép mở rộng linh hoạt và bảo vệ các hạ tầng ảo hóa (như AWS, Azure).

2.4. Giới thiệu Iptables

- Iptables là một chương trình ứng dụng cho phép quản trị viên cấu hình các bảng và quy tắc lọc gói tin của Linux kernel (thông qua module Netfilter).

- Các thành phần chính:

+ Table (Bảng):

Filter: Bảng mặc định để lọc gói tin.

NAT: Dùng để chuyển đổi địa chỉ IP/Port.

Mangle: Dùng để thay đổi các thông số đặc biệt trong Header gói tin.

Raw: Dùng để cấu hình các gói tin ngoại lệ không được theo dõi trạng thái.

+ Chain:

INPUT: Xử lý các gói tin đi vào máy chủ (đích đến là chính máy chủ).

OUTPUT: Xử lý các gói tin từ máy chủ đi ra ngoài.

FORWARD: Xử lý các gói tin đi xuyên qua máy chủ (máy chủ đóng vai trò router).

PREROUTING: Xử lý gói tin ngay khi vừa tới card mạng (trước khi ra quyết định định tuyến).

POSTROUTING: Xử lý gói tin trước khi rời khỏi card mạng.

- Cách hoạt động cơ bản: Khi một gói tin đi vào, Iptables sẽ kiểm tra lần lượt các rule trong Chain tương ứng từ trên xuống dưới. Nếu khớp với một luật nào đó, hành động tương ứng (ACCEPT/DROP/REJECT) sẽ được thực thi và các luật phía dưới sẽ bị bỏ qua. Nếu không khớp với bất kỳ luật nào, gói tin sẽ được xử lý theo Policy mặc định của Chain đó.

CHƯƠNG 3: IDS VÀ CÔNG CỤ SNORT

3.1. Khái niệm IDS

- Định nghĩa: IDS là hệ thống giám sát lưu lượng mạng hoặc các hoạt động hệ thống nhằm phát hiện các hành vi vi phạm chính sách bảo mật hoặc các dấu hiệu tấn công.

- Cơ chế phản ứng: IDS mang tính chất thụ động (Passive). Khi phát hiện dấu hiệu nghi vấn, nó sẽ thực hiện ghi log và gửi cảnh báo (Alert) cho quản trị viên mà không trực tiếp can thiệp để chặn gói tin.

- Chức năng:

+ Giám sát traffic: Theo dõi toàn bộ dữ liệu đi qua phân đoạn mạng hoặc máy chủ theo thời gian thực.

+ Phát hiện tấn công: Đối chiếu dữ liệu với các mẫu tấn công đã biết hoặc các hành vi bất thường để đưa ra cảnh báo (Alert).

3.2. Phân loại IDS

- NIDS (Network-based IDS): Được đặt tại các điểm nút của mạng để giám sát lưu lượng đi qua toàn bộ phân đoạn mạng đó. (Ví dụ: Snort khi cấu hình nghe trên card mạng).

- HIDS (Host-based IDS): Được cài đặt trực tiếp trên một máy chủ cụ thể để giám sát các hoạt động nội tại như file hệ thống, log của hệ điều hành.

3.3. Phương pháp phát hiện

- Signature-based (Phát hiện dựa trên mẫu): So sánh dữ liệu với một cơ sở dữ liệu các mẫu tấn công đã biết (giống như phần mềm diệt virus).

+ Ưu điểm: Độ chính xác cao với các cuộc tấn công cũ.

- + Nhược điểm: Không phát hiện được tấn công mới (Zero-day).
- Anomaly-based (Phát hiện dựa trên bất thường): Thiết lập một "trạng thái bình thường" của hệ thống và đưa ra cảnh báo khi có lưu lượng thay đổi đột ngột (ví dụ: băng thông tăng vọt).
- + Ưu điểm: Có khả năng phát hiện tấn công mới.
- + Nhược điểm: Tỷ lệ cảnh báo giả (False Positive) cao.

3.4. Giới thiệu Snort

- Snort là một hệ thống phát hiện xâm nhập mã nguồn mở phổ biến nhất thế giới, có khả năng phân tích lưu lượng thời gian thực và ghi nhật ký gói tin.
- Các chế độ hoạt động của Snort:
 - + Sniffer mode: Chỉ đọc các gói tin từ mạng và hiển thị chúng lên màn hình (giống như tcpdump).
 - + Packet Logger mode: Ghi lại các gói tin vào đĩa cứng để phân tích sau này.
 - + IDS mode: Chế độ quan trọng nhất. Snort sẽ phân tích gói tin dựa trên bộ luật (Rules) và đưa ra cảnh báo nếu phát hiện xâm nhập.
- Một Rule của Snort gồm hai phần chính: Rule Header và Rule Options.
 - + Cấu trúc tổng quát: Action Protocol Src_IP Src_Port Direction Dst_IP Dst_Port (Options)
 - + Action: Hành động khi khớp luật (alert, log, pass).
 - + Protocol: Giao thức (tcp, udp, icmp, ip).

+ IP & Port: Địa chỉ và cổng nguồn/đích (có thể dùng biến \$HOME_NET, \$EXTERNAL_NET).

+ Direction: Hướng luồng dữ liệu (-> là một chiều, <> là hai chiều).

+ Options: Nằm trong dấu ngoặc đơn, chứa thông điệp cảnh báo (msg), định danh luật (sid), và nội dung cần tìm trong gói tin (content).

CHƯƠNG 4: CÁC DẠNG TẤN CÔNG THỰC NGHIỆM

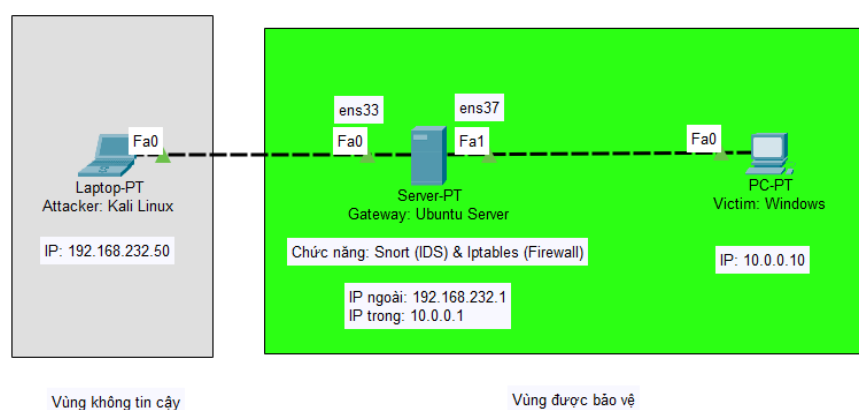
4.1 Mô hình hệ thống

4.1.1 Sơ đồ thực hiện

Sơ đồ mạng mô phỏng quá trình triển khai hệ thống ngăn chặn (Firewall) và phát hiện xâm nhập (IDS) để bảo vệ các tài nguyên quan trọng trong mạng nội bộ. Hệ thống được chia thành 3 thành phần chính:

1. Phân vùng mạng

- Vùng không tin cậy (Untrusted Zone - Màu xám): Đây là môi trường mạng công cộng hoặc mạng bên ngoài, nơi đặt máy Kali Linux (Attacker). Vùng này tiềm ẩn các nguy cơ tấn công mạng.
- Vùng được bảo vệ (Protected Zone - Màu xanh): Đây là mạng nội bộ (LAN), nơi chứa các máy chủ hoặc máy trạm quan trọng, cụ thể là máy Windows (Victim). Vùng này được đặt sau lớp phòng thủ để đảm bảo an toàn thông tin.



Hình 2: Sơ đồ tư duy hệ thống mạng trong Cisco Packet Tracer

2. Các thành phần thiết bị và thông số kỹ thuật

Bảng 2: Thông số kỹ thuật và vai trò của các thiết bị trong hệ thống

Thành phần	Giao diện	Địa chỉ IP	Vai trò / Chức năng chính
Kali Linux (Attacker)	Fa0	192.168.232.50	Giả lập các hành vi tấn công mạng.
Ubuntu Server (Gateway)	ens33	192.168.232.1	Tiếp nhận lưu lượng từ vùng không tin cậy; triển khai Iptables và Snort.
	ens37	10.0.0.1	Cổng mặc định và chuyển tiếp dữ liệu cho mạng nội bộ.
Windows PC (Victim)	Fa0	10.0.0.10	Đối tượng đích cần bảo vệ; nơi tiếp nhận và xử lý các dịch vụ nội bộ.

4.1.2 Nguyên lý hoạt động của luồng dữ liệu

Mọi lưu lượng từ máy Kali muốn đi tới máy Windows bắt buộc phải đi xuyên qua Ubuntu Server:

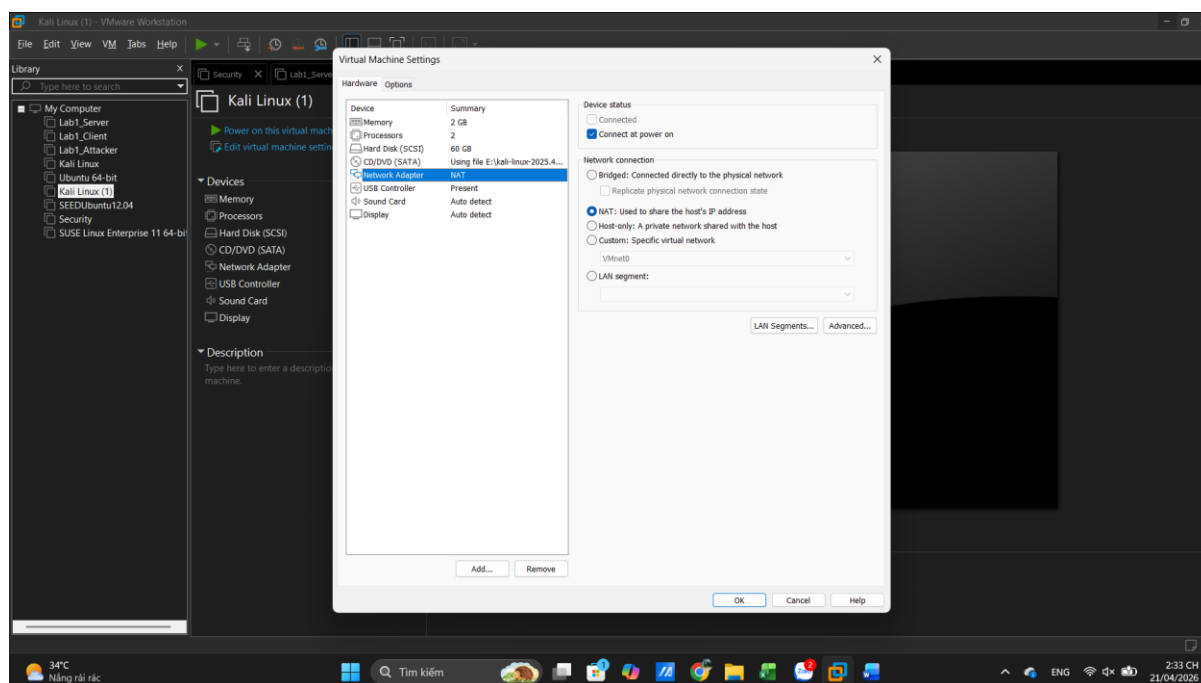
- Giai đoạn 1: Lưu lượng đến interface ens33.
- Giai đoạn 2: Iptables sẽ kiểm tra xem IP/Port có nằm trong danh sách cấm hay không. Nếu hợp lệ, gói tin tiếp tục được chuyển tiếp.
- Giai đoạn 3: Snort tiến hành soi nội dung của gói tin. Nếu phát hiện hành vi quét Nmap hoặc Ping, Snort sẽ ngay lập tức ghi Log và đưa ra cảnh báo.
- Giai đoạn 4: Nếu gói tin an toàn, nó sẽ được đẩy qua interface ens37 để đến máy Windows.

4.2 Cấu hình môi trường ảo hóa (VMware Workstation)

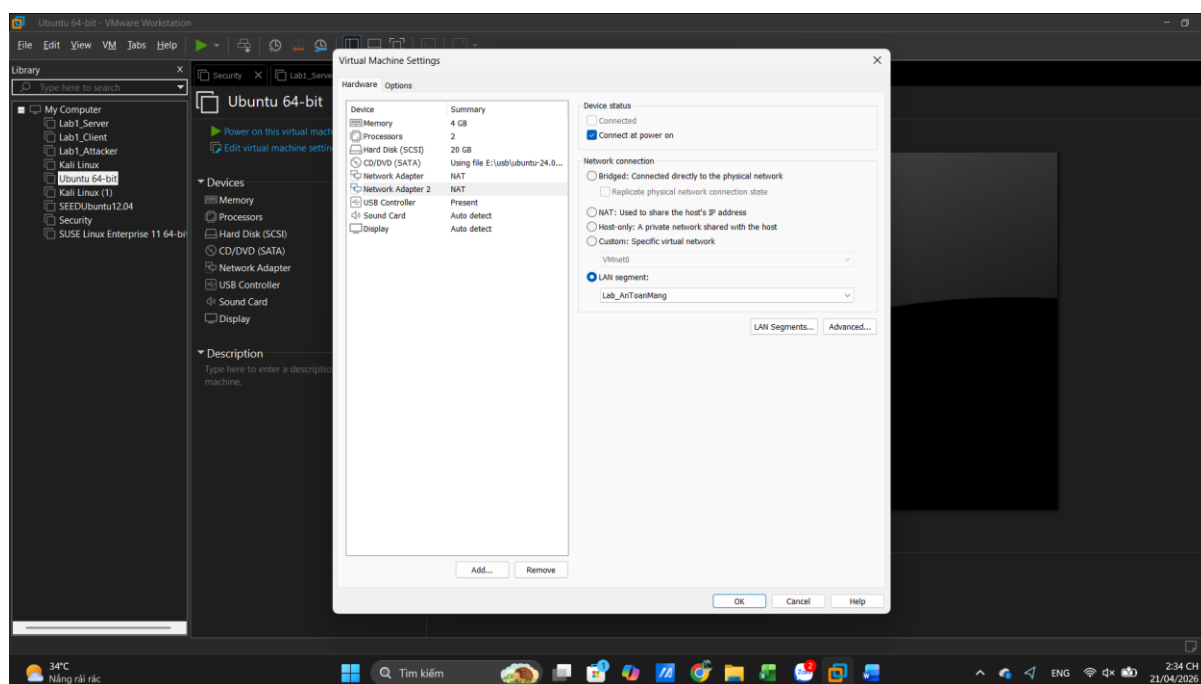
- Để mô phỏng đúng kịch bản, các máy ảo được cấu hình card mạng riêng biệt nhằm cô lập luồng dữ liệu:

- + Máy tấn công (Kali Linux): Sử dụng Card mạng NAT để giao tiếp với Gateway.

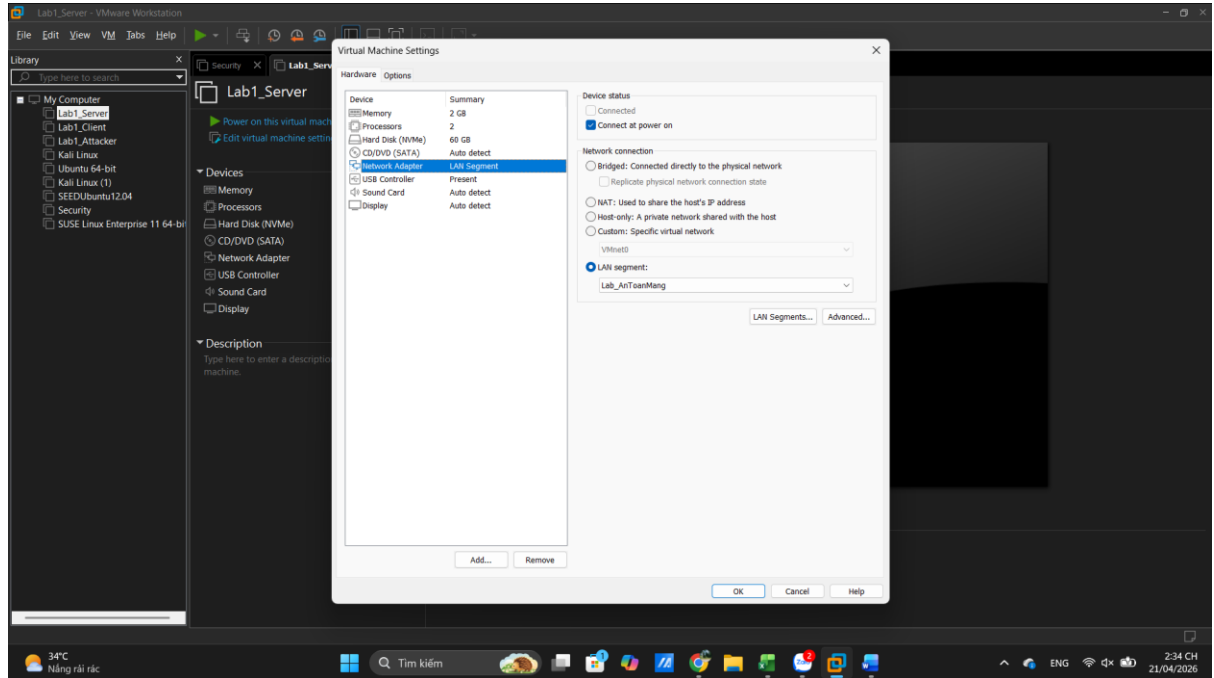
- + Máy chủ Gateway (Ubuntu): Cần 2 Card mạng (1 NAT để nhận dữ liệu từ ngoài, 1 LAN Segment để giao tiếp nội bộ).
- + Máy nạn nhân (Windows): Chỉ kết nối vào mạng nội bộ thông qua LAN Segment.



Hình 3: Cấu hình card mạng cho máy ảo Kali Linux trong VMware Workstation, thiết lập kết nối ở chế độ NAT để giao tiếp với mạng bên ngoài.



Hình 4: Thiết lập card mạng thứ hai cho máy ảo Ubuntu Server, kết nối vào phân đoạn mạng nội bộ (LAN segment: Lab_AnToanMang) để làm vùng được bảo vệ.



Hình 5: Cấu hình card mạng cho máy ảo nạn nhân (Windows) kết nối trực tiếp vào cùng LAN segment với máy chủ Ubuntu để thiết lập mạng nội bộ.

4.3 Cấu hình địa chỉ IP và Định tuyến

4.3.1 Thiết lập IP tĩnh

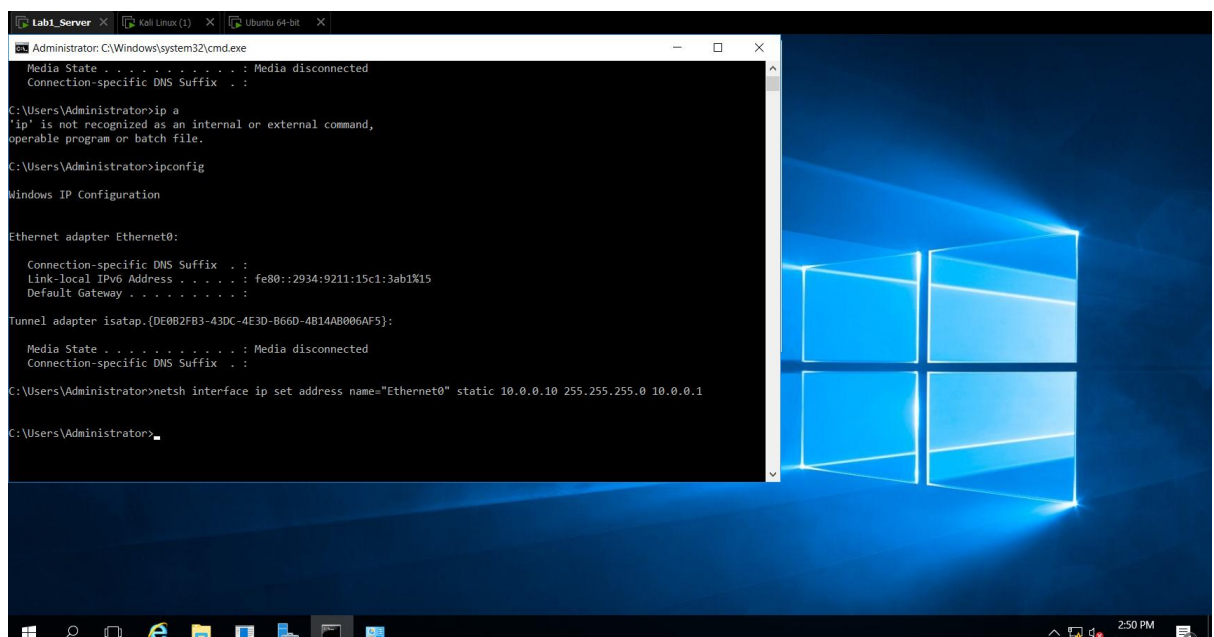
Việc đặt IP cố định là bắt buộc để các dịch vụ mạng và IDS hoạt động chính xác.

- **Trên Ubuntu Server:** Cấu hình file Netplan để quản lý hai giao diện mạng ens33 và ens37.


```
GNU nano 7.2
network:
version: 2
renderer: networkd
ethernets:
  ens33:
    addresses: [192.168.100.20/24]
    nameservers:
      addresses: [8.8.8.8, 1.1.1.1]_
  ens37:
    addresses: [10.0.0.1/24]
```

Hình 6: Giao diện chỉnh sửa file cấu hình Netplan trên Ubuntu Server, thiết lập địa chỉ IP tĩnh cho giao diện ens33 (mạng ngoài) và ens37 (mạng trong: 10.0.0.1/24).

- **Trên Windows:** Sử dụng lệnh để gán IP và trở Default Gateway về máy chủ Ubuntu.



Hình 7: Sử dụng lệnh netsh trong Command Prompt trên Windows để đặt địa chỉ IP tĩnh (10.0.0.10) và Default Gateway (10.0.0.1) cho máy nạn nhân.

4.3.2 Cấu hình Forwarding và Routing

Kích hoạt IP Forwarding: Cho phép Ubuntu Server chuyển tiếp gói tin qua lại giữa hai card mạng.

```
(linh@kali)-[~]
$ sudo sysctl -w net.ipv4.ip_forward=1
net.ipv4.ip_forward = 1

(linh@kali)-[~]
$ echo "net.ipv4.ip_forward=1" | sudo tee -a /etc/sysctl.conf
net.ipv4.ip_forward=1

(linh@kali)-[~]
$
```

Hình 8: Kích hoạt tính năng chuyển tiếp IP trên Linux bằng lệnh sysctl, cho phép máy chủ đóng vai trò như một Router chuyển tiếp gói tin.

Thiết lập Static Route: Khai báo đường đi trên máy tấn công để nó biết cách gửi gói tin đến dải mạng 10.0.0.0/24.

```
(linh@kali)-[~]
$ sudo ip route add 10.0.0.0/24 via 192.168.232.1
[sudo] mật khẩu dành cho linh:

(linh@kali)-[~]
$
```

Hình 9: Thực hiện lệnh thêm định tuyến tĩnh trên Kali Linux để chỉ định đường đi đến dải mạng nội bộ 10.0.0.0/24 thông qua Gateway 192.168.232.1.

4.4 Kiểm tra và Giám sát hệ thống

4.4.1 Kiểm tra kết nối

Sử dụng lệnh Ping để đảm bảo các máy đã thấy nhau thông qua Gateway.

```

linh@ubuntu:~$ ping 192.168.232.50
PING 192.168.232.50 (192.168.232.50) 56(84) bytes of data.
64 bytes from 192.168.232.50: icmp_seq=1 ttl=64 time=2.72 ms
64 bytes from 192.168.232.50: icmp_seq=2 ttl=64 time=1.19 ms
64 bytes from 192.168.232.50: icmp_seq=3 ttl=64 time=1.19 ms
64 bytes from 192.168.232.50: icmp_seq=4 ttl=64 time=1.18 ms
64 bytes from 192.168.232.50: icmp_seq=5 ttl=64 time=1.41 ms
64 bytes from 192.168.232.50: icmp_seq=6 ttl=64 time=1.20 ms
64 bytes from 192.168.232.50: icmp_seq=7 ttl=64 time=1.17 ms
64 bytes from 192.168.232.50: icmp_seq=8 ttl=64 time=1.30 ms
64 bytes from 192.168.232.50: icmp_seq=9 ttl=64 time=1.01 ms
64 bytes from 192.168.232.50: icmp_seq=10 ttl=64 time=1.34 ms
^C
--- 192.168.232.50 ping statistics ---
10 packets transmitted, 10 received, 0% packet loss, time 9018ms
rtt min/avg/max/mdev = 1.008/1.371/2.717/0.460 ms
linh@ubuntu:~$ ping 10.0.0.10
PING 10.0.0.10 (10.0.0.10) 56(84) bytes of data.
64 bytes from 10.0.0.10: icmp_seq=1 ttl=128 time=2.53 ms
64 bytes from 10.0.0.10: icmp_seq=2 ttl=128 time=0.980 ms
64 bytes from 10.0.0.10: icmp_seq=3 ttl=128 time=1.27 ms
64 bytes from 10.0.0.10: icmp_seq=4 ttl=128 time=1.15 ms
64 bytes from 10.0.0.10: icmp_seq=5 ttl=128 time=0.725 ms
64 bytes from 10.0.0.10: icmp_seq=6 ttl=128 time=1.41 ms
64 bytes from 10.0.0.10: icmp_seq=7 ttl=128 time=1.86 ms
64 bytes from 10.0.0.10: icmp_seq=8 ttl=128 time=1.19 ms
^C
--- 10.0.0.10 ping statistics ---
8 packets transmitted, 8 received, 0% packet loss, time 7012ms
rtt min/avg/max/mdev = 0.725/1.388/2.527/0.528 ms
linh@ubuntu:~$

```

Hình 10: Kiểm tra kết nối mạng bằng lệnh Ping từ máy chủ Ubuntu tới cả máy tấn công (192.168.232.50) và máy nạn nhân (10.0.0.10) để xác nhận thông suốt.

4.4.2 Cấu hình luật cho Snort IDS

Đây là phần cốt lõi của báo cáo, thiết lập các chữ ký để hệ thống tự động phát hiện tấn công.

- **Luật 1:** Cảnh báo khi có máy thực hiện Ping.

Dòng luật này dùng để phát hiện các gói tin ICMP (thường là lệnh ping) từ máy có IP 192.168.232.50 gửi đến máy mục tiêu 10.0.0.10.

```

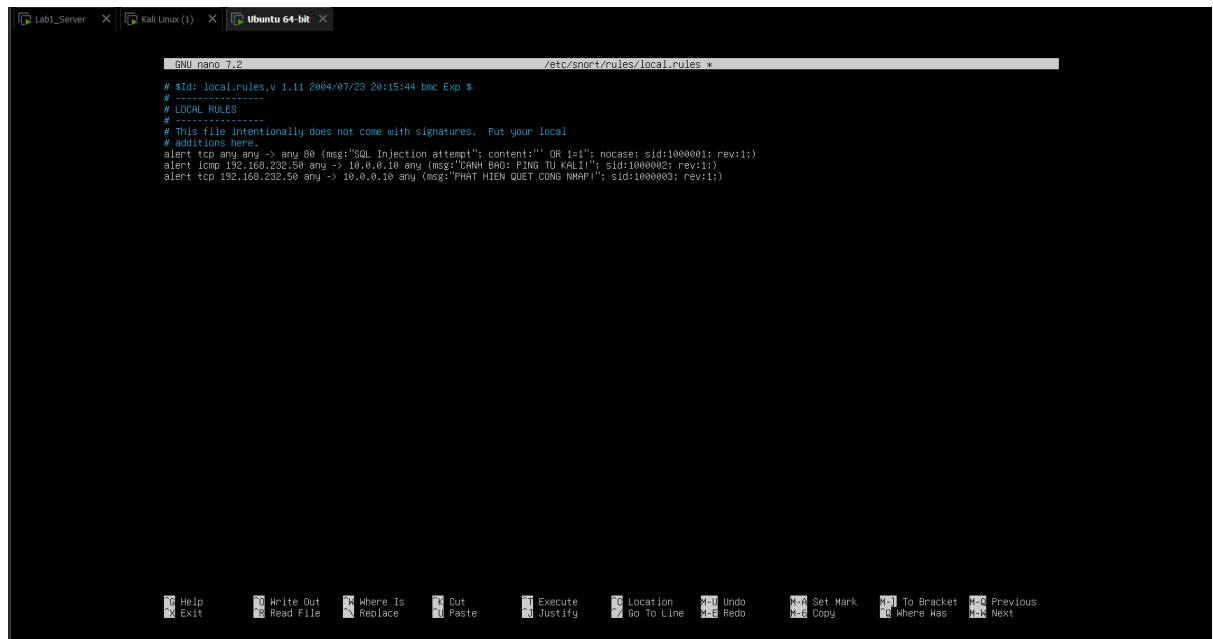
alert icmp 192.168.232.50 any -> 10.0.0.10 any (msg:"CANH BAO: PING
TU KALI!"; sid:1000002; rev:1;)

```

- **Luật 2:** Phát hiện hành vi quét cổng bằng Nmap.

Dòng luật này dùng để phát hiện các kết nối TCP từ máy tấn công 192.168.232.50 đến máy mục tiêu 10.0.0.10, thường xuất hiện trong các kỹ thuật quét cổng của Nmap.

```
alert tcp 192.168.232.50 any -> 10.0.0.10 any (msg:"PHAT HIEN QUET CONG NMAP!"; sid:1000003; rev:1;)
```



```
GNU nano 7.2 /etc/snort/rules/local.rules *
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
# -----
# LOCAL RULES
# -----
# This file intentionally does not come with signatures. Put your local
# additions here.
alert tcp any any -> any 80 (msg:"SQL Injection attempt"; content:"' OR 1=1"; nocase; sid:1000001; rev:1;)
alert icmp 192.168.232.50 any -> 10.0.0.10 any (msg:"DANH BAO: PING TU KALI!"; sid:1000002; rev:1;)
alert tcp 192.168.232.50 any -> 10.0.0.10 any (msg:"PHAT HIEN QUET CONG NMAP!"; sid:1000003; rev:1;)
```

Hình 11: Cấu hình các luật tùy chỉnh trong file *local.rules* của Snort IDS để phát hiện các gói tin ICMP và hành vi quét cổng Nmap.

CHƯƠNG 5: SO SÁNH FIREWALL VS IDS

Trong kiến trúc an ninh mạng hiện đại, Firewall và IDS là hai thành phần cốt lõi, bổ trợ cho nhau để tạo nên một hệ thống phòng thủ vững chắc. Mặc dù cả hai đều hướng tới mục tiêu bảo vệ tài nguyên mạng, nhưng chúng hoạt động ở các lớp và cơ chế khác nhau.

Nếu Firewall được ví như một người gác cổng nghiêm ngặt, chuyên lọc lưu lượng dựa trên các quy tắc định sẵn tại cửa ngõ, thì IDS lại đóng vai trò như một hệ thống camera giám sát thông minh, có khả năng phân tích sâu vào nội dung gói tin để phát hiện các dấu hiệu tấn công tinh vi. Sự kết hợp giữa Iptables và Snort giúp quản trị viên vừa có thể ngăn chặn các truy cập trái phép, vừa có thể nhận cảnh báo kịp thời về các hành vi xâm nhập tiềm tàng.

Bảng 3: Các tiêu chí đánh giá khác biệt giữa Iptables và Snort trong an toàn mạng.

Tiêu chí	Firewall (Iptables)	IDS (Snort)
Chức năng chính	Ngăn chặn: Cho phép hoặc từ chối lưu lượng dựa trên các quy tắc tĩnh.	Phát hiện: Giám sát, phân tích và đưa ra cảnh báo về các hành vi xâm nhập.
Vị trí	Đứng ở cửa ngõ mạng hoặc ranh giới giữa các vùng mạng.	Thường nằm ở vị trí có thể soi được toàn bộ lưu lượng (Mirror port/Tap).
Cơ chế xử lý	Dựa trên Header gói tin (IP, Port, Protocol).	Dựa trên cả Header và Nội dung (Payload) gói tin.
Phản ứng	Chặn gói tin ngay lập tức theo thời gian thực.	Gửi cảnh báo đến quản trị viên hoặc ghi Log.
Độ thông minh	Thấp (chỉ làm theo luật có sẵn).	Cao (hiểu được các mẫu hành vi tấn công phức tạp).

CHƯƠNG 6: DEMO

Để minh chứng cho quá trình triển khai và kiểm thử hệ thống Firewall (Iptables) kết hợp IDS (Snort), nhóm đã thực hiện video ghi lại toàn bộ quá trình vận hành thực tế. Video bao gồm các nội dung chính:

- Thiết lập và kiểm tra kết nối giữa các phân vùng mạng.
- Cấu hình các luật chặn trên Iptables và luật phát hiện xâm nhập trên Snort.
- Thực hiện các kịch bản tấn công giả lập và quan sát phản ứng của hệ thống (Log & Alert).

Quý thầy có thể xem video bằng cách quét mã QR bên dưới hoặc truy cập trực tiếp qua đường dẫn:

1. Mã QR truy cập nhanh:



Hình 12: Mã QR truy cập video demo trên YouTube.

2. Đường dẫn trực tiếp:

Link YouTube: <https://youtu.be/NGW7gABLz1o>

TÀI LIỆU THAM KHẢO

- [1] Netfilter Project, "Netfilter/iptables documentation," [Online]. Available: <https://www.netfilter.org/documentation/>. [Accessed: Apr. 23, 2026].
- [2] Snort, "Snort Documentation," [Online]. Available: <https://www.snort.org/documents>. [Accessed: Apr. 23, 2026].
- [3] G. Lyon, *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*. [Online]. Available: <https://nmap.org/book/>. [Accessed: Apr. 23, 2026].
- [4] OWASP Foundation, "Open Web Application Security Project (OWASP) Home Page," [Online]. Available: <https://owasp.org>. [Accessed: Apr. 23, 2026].
- [5] N. H. Nguyễn, *Giáo trình An toàn và Bảo mật hệ thống thông tin*. Hà Nội, Việt Nam: NXB Bách Khoa Hà Nội, 2020.
- [6] Học viện Công nghệ Bưu chính Viễn thông, "Bài giảng An toàn bảo mật mạng," Tài liệu lưu hành nội bộ, Hà Nội, Việt Nam.